

Отчёт по лабораторной работе 4

Среда: OWASP Juice Shop (localhost:3000) | Дата: 11.08.2026

ЛР_4 — Утечка конфиденциальных документов + неподписанный JWT (A04)

Часть 1 — Утечка конфиденциальных документов через публичный файловый раздел

Что сделано:

Через раздел About Us → Terms of Use обнаружен публичный FTP-каталог /ftp/ с листингом директории. Среди файлов найдены конфиденциальные документы: acquisitions.md (планы поглощения конкурентов с грифом «confidential») и coupons_2013.md.bak (резервная копия купонов). Файлы доступны без аутентификации любому посетителю.

Доказательства:

- Листинг директории /ftp/ доступен публично — раскрывает все файлы каталога
- acquisitions.md: «Planned Acquisitions. This document is confidential! Do not distribute!» — планы поглощения конкурентов
- coupons_2013.md.bak: зашифрованные купоны продавца
-  Confidential Document +  Forgotten Sales Backup

Ключевая причина:

Отсутствие контроля доступа к файловому разделу /ftp/. Сервер разрешает листинг директории и не требует аутентификации для доступа к внутренним документам. Конфиденциальные файлы (резервные копии, бизнес-планы) хранятся в публично доступной области.

Потенциальные последствия:

- Утечка конфиденциальной бизнес-информации (планы поглощений, купоны)
- Раскрытие внутренней структуры файлов и зависимостей (package.json.bak)
- Использование инсайдерской информации для биржевых манипуляций

Исправление / профилактика:

- Закрыть публичный доступ к /ftp/, требовать аутентификацию
- Отключить листинг директорий (auto-index) на веб-сервере
- Классифицировать данные и применять политики доступа на основе классификации
- Не хранить конфиденциальные/резервные файлы в рабочих каталогах приложения

Часть 2 — Неподписанный JWT-токен

Что сделано:

После входа под обычным пользователем (labuser@test.com) получен JWT-токен с алгоритмом RS256. Токен декодирован из base64url. Заголовок изменён: alg заменён на «none». В полезной нагрузке email заменён на jwt3d@juice-sh.op

(несуществующий пользователь). Токен перекодирован без подписи (сегмент подписи пуст). Сервер принял подделанный токен, подтвердив отсутствие проверки подписи.

Доказательства:

- Оригинальный заголовок: {"typ":"JWT","alg":"RS256"}
- Оригинальная payload: {"data": {"id":24,"email":"labuser@test.com","role":"customer",...},"bid":6}
- Подделанный заголовок: {"typ":"JWT","alg":"none"}
- Подделанная payload: email изменён на jwt3d@juice-sh.op
- GET /rest/user/whoami с подделанным токеном принят сервером (HTTP 200)
-  Unsigned JWT

Ключевая причина:

Сервер не проверяет алгоритм подписи JWT. Библиотека jsonwebtoken (версия ~8) по умолчанию допускает токены с alg:none, если в конфигурации явно не запрещено. Сервер доверяет заголовку токена, в котором атакующий может указать «алгоритм отсутствует».

Потенциальные последствия:

- Полная подделка личности любого пользователя
- Повышение привилегий до администратора (при подстановке role:admin)
- Доступ к любым защищённым API-эндпоинтам без реальной аутентификации

Исправление / профилактика:

- Явно отключить alg:none в конфигурации библиотеки JWT: algorithms: ['RS256']
- Фиксировать список разрешённых алгоритмов (whitelist), отклонять всё остальное
- Проверять issuer, audience, срок действия и подпись с использованием корректных ключей
- Использовать библиотеки с безопасными настройками по умолчанию (например, jose вместо jsonwebtoken)